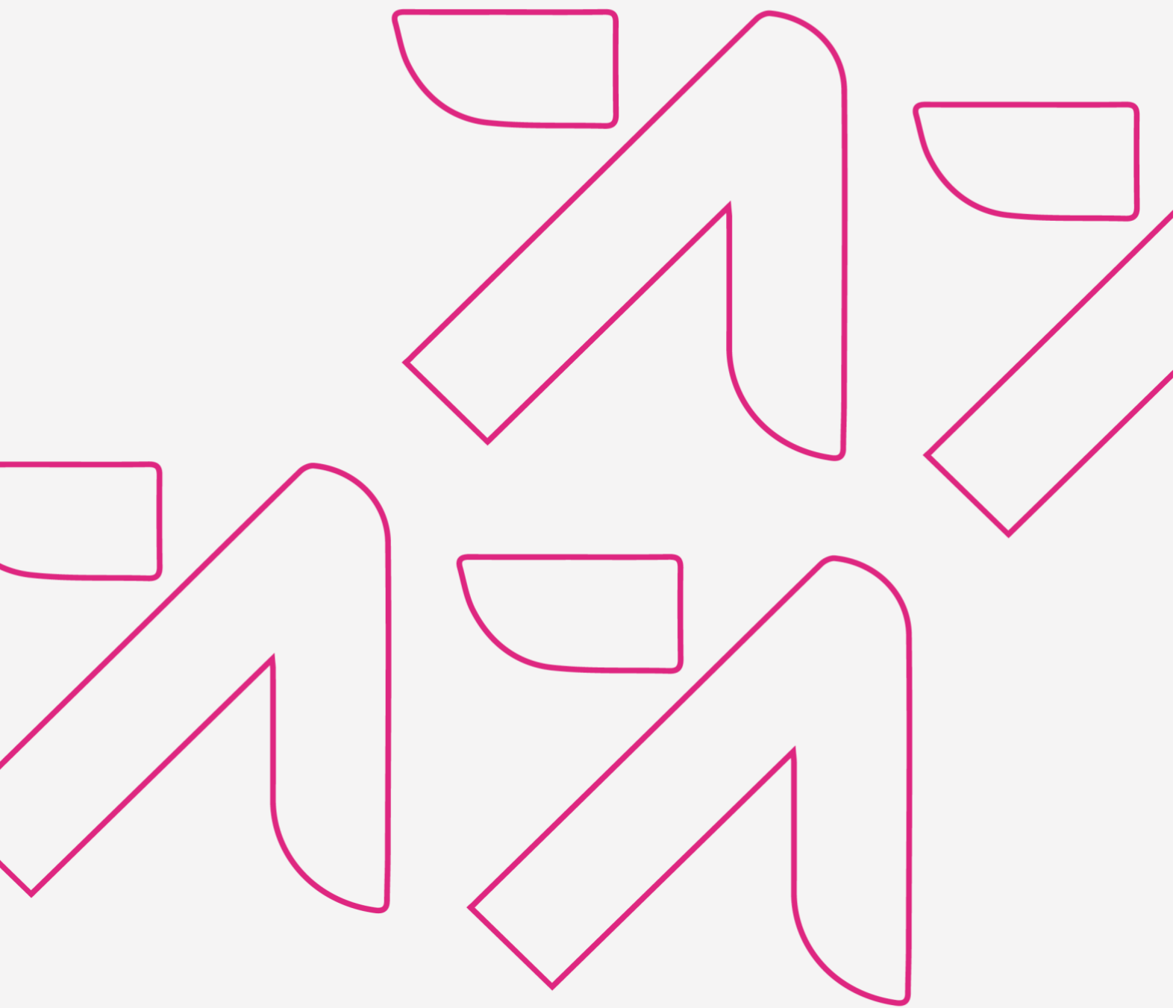




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT6. Seguridad en redes inalámbricas y movilidad

Encaje en el curso 2026/2027: esta unidad desarrolla la parte inalámbrica del RA4 (tema 7: seguridad wifi WPA2/WPA3) y se apoya en el 802.1X del RA3 (tema 5).

1. Objetivo de la seguridad inalámbrica

La seguridad en redes WiFi y dispositivos móviles busca asegurar que el acceso inalámbrico no se convierta en un punto débil dentro de la arquitectura de la organización. Una red inalámbrica mal configurada es una puerta abierta para intrusiones, robo de credenciales, movimientos laterales y espionaje de tráfico.

La idea central es: **mismo nivel de seguridad que la red cableada, o superior**.

2. Amenazas específicas en redes inalámbricas

2.1. Rogue Access Points

Puntos de acceso falsos creados por un atacante que imitan la red legítima para capturar tráfico o credenciales.

2.2. Evil Twin

AP falso que clona SSID, BSSID y configuración para engañar a usuarios.

2.3. Sniffing de tráfico

Captura de paquetes en redes abiertas o con cifrados débiles.

2.4. Ataques de autenticación

- Desautenticación (deauth): expulsar a clientes de la red para forzar que se reconecten
- Captura de handshakes WPA/WPA2
- Fuerza bruta u offline cracking
- Ataques contra portales cautivos

2.5. Riesgos BYOD

Dispositivos personales inseguros que acceden a la red corporativa.

3. Arquitectura de red WiFi segura

3.1. Separación de SSID

Cada red con un propósito distinto:

- **SSID corporativo:** solo para empleados.
- **SSID de invitados:** completamente separado de la red interna.

- **SSID IoT/OT:** aislamiento total de dispositivos no confiables.
- **SSID administración:** extremo restringido, solo para personal técnico.

3.2. Segmentación

Cada SSID debe mapearse a:

- VLAN diferente
- Reglas de firewall específicas
- Políticas de acceso diferenciadas

3.3. Control de acceso

Nunca se debe permitir que usuarios o IoT compartan red con servicios internos.

4. Protocolos de seguridad WiFi

4.1. WPA3 (obligatorio en despliegues modernos)

- SAE (Simultaneous Authentication of Equals)
- Protege contra ataques offline
- Tramas de gestión protegidas (PMF, 802.11w) obligatorias: frenan los ataques de desautenticación
- Secreto hacia adelante: capturar tráfico hoy no permite descifrarlo aunque la contraseña se filtre más adelante
- Mejor confidencialidad

4.2. WPA2-Enterprise (802.1X + RADIUS)

El estándar corporativo más extendido:

- Autenticación por certificados o credenciales
- Identidad individual para cada usuario
- Control robusto del acceso

4.3. WPA3-Enterprise y métodos EAP

- WPA3-Enterprise mantiene 802.1X y añade un modo de 192 bits para entornos sensibles.
- **EAP-TLS** (certificado en cada dispositivo) es la opción más robusta: no hay contraseña que robar.
- **PEAP-MSCHAPv2** (usuario y contraseña) solo es aceptable si los clientes validan el certificado del servidor RADIUS; si no, un Evil Twin captura las credenciales.

4.4. Evitar WPA2-Personal

Clave compartida, insegura para entornos corporativos.

4.5. Prohibido WPA, WEP

Cifrados obsoletos vulnerables.

4.6. Lo que cambia con las bandas nuevas

En 6 GHz (Wi-Fi 6E y Wi-Fi 7) WPA3 es obligatorio y no existen redes abiertas sin cifrar: las redes «abiertas» usan **OWE** (Enhanced Open), que cifra el tráfico de cada cliente aunque no haya contraseña. Es la opción recomendable para redes de invitados.

5. Seguridad 802.1X y RADIUS

5.1. Funcionamiento básico

- Cliente solicita acceso
- Punto de acceso redirige a servidor RADIUS
- RADIUS verifica identidad
- Si ok: asigna VLAN y permisos
- Si no: deniega

5.2. Ventajas

- Control granular
- Identidades únicas
- Revocación instantánea
- Integración con Active Directory o LDAP

6. Diseño seguro del AP y la infraestructura

6.1. Configuración del AP

- Potencia ajustada para evitar fugas fuera del perímetro
- Deshabilitar WPS
- No anunciar información innecesaria en las balizas. Ocultar el SSID no aporta seguridad: se descubre en segundos y hace que los clientes lo vayan pregonando
- Actualizar el firmware de puntos de acceso y controladora, y cambiar las credenciales de gestión por defecto
- Filtrar MAC no aporta seguridad real (evitar como “medida principal”)

6.2. Firewalls en redes inalámbricas

Reglas específicas:

- Bloquear tráfico lateral entre clientes
- Separar tráfico de invitado del resto
- Limitar puertos permitidos

6.3. Aislamiento del cliente

Evita que los dispositivos se vean entre sí. Fundamental en invitados e IoT.

7. Seguridad en movilidad (BYOD y MDM)

7.1. BYOD

Permitir dispositivos personales requiere controles estrictos:

- Red totalmente separada
- No acceso a recursos internos sensibles
- NAC (Network Access Control) opcional para validar estado del dispositivo

7.2. MDM (Mobile Device Management)

Administración centralizada de dispositivos corporativos:

- Políticas de seguridad obligatorias
- Cifrado del dispositivo
- Borrado remoto
- Control de apps instaladas
- Restricciones de WiFi, Bluetooth, hotspot

7.3. Problemas comunes

- Dispositivos no cifrados
- Apps inseguras
- Uso de redes públicas sin VPN
- Sin control de parches en móviles

8. Redes WiFi de invitados

8.1. Requisitos mínimos

- VLAN separada
- Solo acceso a Internet
- Bloqueo total hacia red interna
- Captive portal opcional

8.2. Limitación de ancho de banda

Evita abusos y mantiene rendimiento para la red corporativa.

8.3. Expiración del acceso

Accesos temporales vinculados a persona o dispositivo.

9. Detección y respuesta en redes inalámbricas

9.1. Monitorización continua

- Escaneo pasivo de AP falsos
- Alarmas por SSID clonados
- Alertas por aumentos de fallos de autenticación

9.2. Logs del controlador WiFi

Registrar:

- Asociaciones/desasociaciones
- Intentos fallidos
- Cambios de canal
- Eventos de seguridad (Rogue AP detectado)

9.3. Detección de comportamiento anómalo

- Dispositivos que saltan entre SSID
- Tráfico excesivo
- Dispositivos intentando ofrecer DHCP o DNS (indicador clave)

10. Buenas prácticas globales

- WPA3 o WPA2-Enterprise siempre.
- SSID separados por función, nunca mezclar.
- Aislamiento de clientes activado.
- Segmentación y firewall para cada segmento inalámbrico.
- Deshabilitar WPS.
- Revisiones periódicas de cobertura y potencia.
- Monitorización activa contra Rogue AP.
- MDM para dispositivos corporativos.
- BYOD estrictamente aislado, nunca en la red interna.

Para ampliar

- Guía CCN-STIC 816: seguridad en redes inalámbricas.
- Especificación WPA3 de la Wi-Fi Alliance.
- INCIBE: guías de seguridad en redes wifi y de uso de dispositivos móviles en la empresa.